

FREE GOVERNANCE GUIDE · V1.1 · OCTOBER 2026

Safe AI Use Guide

Six chapters written for community banks and credit unions.
Aligned with SR 26-2 (the April 2026 model-risk guidance that superseded SR 11-7), Interagency TPRM Guidance, ECOA / Reg B, and the AIEOG AI Lexicon (US Treasury, FBIIC, FSSCC, February 2026).

CONTENTS

1. The never-paste list
2. Private cloud vs. public model
3. Mapping to SR 26-2
4. Vendor evaluation scoring
5. Shadow AI discovery
6. Examiner readiness

CHAPTER 01

The never-paste list

Six categories of data that must never go into a public large language model, and the legal reasoning behind each prohibition.

STANDING RULE — NO EXCEPTIONS

A public LLM is a third party. Anything entered into a public LLM prompt leaves your institution's security perimeter. When a data category is not listed here, apply the same test: would you email this to an unknown vendor? If not, do not paste it.

DATA CATEGORY	COMMON EXAMPLES	LEGAL BASIS
Customer / member PII	Names, SSNs, account numbers, dates of birth, addresses, phone numbers, email addresses	GLBA information-security standards require you to protect customer information and oversee every service provider that touches it. A public LLM is an unvetted service provider.
Loan application data	Income, employment history, credit scores, debt schedules, collateral values	ECOA / Reg B, FCRA, and fair lending obligations attach to this data. Credit analysis by an unvalidated tool is a model-risk and fair-lending problem (see Chapter 3).
Confidential supervisory information	CAMELS ratings, MRAs / MRIAs, examination reports, supervisory correspondence	This information belongs to the agency, not the institution. Agency rules prohibit disclosing it without the agency's consent.
BSA / AML records	SAR narratives, CTR details, OFAC screening results, beneficial ownership records	Federal law prohibits disclosing a SAR or any information that would reveal one (31 U.S.C. § 5318(g)(2)). Once pasted, it cannot be recalled.

DATA CATEGORY	COMMON EXAMPLES	LEGAL BASIS
Internal audit & legal	Draft audit findings, attorney-client communications, litigation-hold materials	Disclosure to a third party can waive privilege. Public LLM terms of service typically do not preserve attorney-client or work-product protection.
Vendor contracts & pricing	Core processor MSAs, fintech contracts, negotiated rate schedules	Most contracts carry confidentiality clauses. Disclosure to a public LLM may be a breach that creates liability.

PRACTICAL STAFF TEST

Before pasting, ask: "Does this contain a real person's information, a real account's data, or information I received under an expectation of confidentiality?" If yes to any, stop. Use only synthetic or fully anonymized data for AI-assisted drafting and analysis.

Legal basis: GLBA § 501(b) and the Interagency Guidelines Establishing Information Security Standards (12 C.F.R. Part 30, App. B; Part 208, App. D-2; Part 364, App. B); NCUA 12 C.F.R. Part 748, App. A; ECOA / Reg B (12 C.F.R. Part 1002); 31 U.S.C. § 5318(g)(2); confidential supervisory information rules at 12 C.F.R. 4.36–4.37 (OCC), Part 261 (FRB), and 309.6 (FDIC).

Private cloud vs. public model

A decision tree every staff member runs before entering data into any AI tool. Five questions. One clear answer.

Not every AI use case needs private infrastructure. Walk the questions in order and stop at the first answer that sets a deployment tier.

Q1 Does the task require any data from the never-paste list (Chapter 1)?

Yes → Private inference required. Approved private cloud or on-premises deployment only. Public models prohibited.

No → Continue to Q2.

Q2 Will the output be used to make or support a credit, compliance, or hiring decision?

Yes → Private inference required. Treat the tool as a model: validation, documentation, and independent review before use. SR 26-2 (which superseded SR 11-7 in April 2026) covers traditional and non-generative AI models. It leaves generative AI outside its scope, so your own governance has to supply the same controls.

No → Continue to Q3.

Q3 Do the vendor's terms permit training on submitted data?

Yes → Public model not permitted for internal use cases. Evaluate an enterprise tier with a training opt-out, or private deployment.

No (training opt-out confirmed in writing) → Continue to Q4.

Q4 Is the data classified Internal Only (not public-facing, not restricted)?

Yes → Enterprise-licensed tier required (for example, Microsoft 365 Copilot or Google Workspace Gemini with DLP controls). Consumer and free-tier tools prohibited.

No (data is genuinely public or synthetic) → Continue to Q5.

Q5 Is the tool on your institution's approved AI vendor list?

Yes (approved tool, public data only) → Public model permitted. Record the use case in your AI use case inventory.

No → Do not use. Submit it for vendor evaluation (Chapter 4) first.

Framework basis: SS&C Managed IT, Hybrid Multi-Cloud AI Strategy (2025): keep PII out of public LLMs, use private cloud for sensitive inference, and apply Zero Trust with role-based access. SR 26-2, Revised Guidance on Model Risk Management (FRB / OCC / FDIC, April 17, 2026). AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC (February 2026).

Mapping to SR 26-2

SR 26-2 replaced SR 11-7 as the interagency model-risk guidance in April 2026. It was written for statistical and non-generative AI models, but its principles are still the clearest frame for governing generative AI. Here is the mapping, with action language for your framework.

What SR 26-2 does and does not do. SR 26-2 (FRB / OCC / FDIC, April 17, 2026) superseded SR 11-7 (2011) and SR 21-8 (2021). It is non-binding: falling short of the guidance does not by itself draw supervisory criticism, though unsafe or unsound model-risk practices still can. It is aimed mainly at banking organizations over \$30 billion in assets. Generative and agentic AI are outside its scope; the agencies say a bank's own risk management and governance should set the controls for those tools. Per GAO-25-107197 (May 2025), there is no comprehensive AI-specific banking framework. Read this table as a reasoning frame, not a compliance checklist.

SR 26-2 PRINCIPLE	GENERATIVE AI EQUIVALENT	ACTION FOR YOUR FRAMEWORK
Model development and use	System selection and deployment	Document the intended use case, data inputs, and business process before deployment. Assign an owner. Re-review whenever use expands beyond the original purpose.
Validation: conceptual soundness and outcomes analysis	Output accuracy and hallucination testing	Set a review process sized to the stakes. For credit and compliance outputs, require human review of AI-generated content before use.
Ongoing monitoring	Drift and output-quality degradation	Track output quality over time. Re-evaluate whenever the vendor updates the underlying foundation model.
Model inventory	AI use case inventory	Keep a living register of every AI tool in use, its data inputs, business purpose, and risk tier. The AIEOG AI Lexicon calls this the "AI use case inventory."
Vendor and third-party products	Vendor and API-based AI services	Apply Interagency TPRM Guidance to every AI vendor. SR 26-2 notes vendors may not share code or data, but the principles still apply. Obtain SOC 2 Type II, review retention terms, confirm a right-to-audit clause.
Effective challenge	Adversarial / red-team testing	For any AI used in lending or compliance work, test for prompt injection, jailbreaks, and data leakage before production, by someone independent of the build.
Roles, responsibilities, and audit	AI governance committee	Stand up a cross-functional committee (IT, Compliance, Risk, Operations, Audit) with a quarterly review cadence and board reporting.

Sources: SR 26-2 and attachment, Revised Guidance on Model Risk Management, FRB / OCC / FDIC (April 17, 2026), superseding SR 11-7 (2011) and SR 21-8 (2021). GAO-25-107197, US Government Accountability Office (May 2025). AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC (February 2026).

Vendor evaluation scoring

Five questions, scored 0–3 each, for a maximum of 15. Minimum passing score: 9. Below 9, do not deploy without a remediation plan and board notification.

15

Approved

12-14Approved with
conditions**9-11**Conditional —
remediation required**Below 9**

Do not deploy

QUESTION	3	2	1	0
Q1 • Data handling and retention. Contractual commitment to no training on your data? Retention documented and within TPRM policy?	Written opt-out confirmed; data deleted within 30 days	Training opt-out available; retention unclear	No opt-out; data retained for model improvement	Terms silent on training or retention
Q2 • Security certifications. SOC 2 Type II, ISO 27001, or FedRAMP, current within 12 months?	SOC 2 Type II current; penetration test available	SOC 2 Type I or ISO 27001 only	Certification in progress	No third-party security certification
Q3 • Right to audit and subprocessors. Right-to-audit clause? Material subprocessors disclosed and held to equivalent controls?	Right to audit confirmed; subprocessors listed and auditable	Audit limited to questionnaire; subprocessors disclosed	No right to audit; subprocessors partly disclosed	Contract silent; subprocessors not disclosed
Q4 • Concentration risk. What share of your AI-dependent workflows would this vendor carry?	Under 25%; redundancy plan exists	25–50%; backup vendor identified	Over 50%; no fallback plan	Single point of failure; no contingency
Q5 • Explainability and human-in-the-loop. Does the system explain its reasoning? Is human review required before action?	Explanations available; HITL required by workflow design	Explanations on request; HITL optional	Limited explainability; HITL not enforced	Black-box output; no human review step

Framework basis: Interagency Guidance on Third-Party Relationships: Risk Management (OCC, FRB, FDIC, June 2023). AIEOG AI Lexicon terms "human-in-the-loop (HITL)," "explainability," and "third-party AI risk" (February 2026). Scoring thresholds are the Institute's recommended starting point. Adapt before adoption.

Shadow AI discovery

A five-phase method for finding the AI tools your staff already use, and bringing them inside a governance perimeter without killing adoption.

WHY THIS MATTERS NOW

Gartner Peer Community data (via Jack Henry, 2025) found 57% of financial institutions reported AI skill gaps and 55% had no AI governance framework. The common root cause: staff adopted tools before governance existed. A punitive discovery process drives shadow AI further underground. This method surfaces tools through trust, not surveillance.

Phase 1 • Anonymous discovery survey

WEEK 1

Send all staff a short anonymous survey: "What AI tools do you use in your work, including personal tools?" Guarantee that management will not review individual responses. Psychological safety is the key variable; without it, staff underreport.

Output: raw inventory of AI tools in use, by department.

Phase 2 • DNS / proxy log review

WEEKS 1-2

Pull 30 days of outbound DNS queries or proxy logs. Search for known AI domains (openai.com, claude.ai, gemini.google.com, perplexity.ai, and newer tools). Cross-reference against the approved vendor list.

Output: gap list of tools in use but not on the approved inventory.

Phase 3 • Department interviews

WEEKS 2-3

Hold 20-minute structured interviews with department heads. Ask: "Walk me through a week of work. Where do you use AI?" Open with productivity, not compliance. Lending, Operations, and IT usually surface the most shadow AI.

Output: use-case map per department, with high-risk workflows flagged.

Phase 4 • Risk classification

WEEK 3

Run each discovered tool through the Chapter 2 decision tree. Tools that need private inference but run on public models are Tier 1 remediation priorities.

Output: risk-tiered shadow AI register.

Phase 5 • Governance integration

WEEK 4

Score each tool with the Chapter 4 framework. Tools scoring 9 or more and matched to an approved data tier go into the official AI use case inventory. For tools below 9, notify users, provide approved alternatives, and document the decision.

Output: updated AI use case inventory and closure notices to affected staff.

Data: "Getting Started in AI," Jack Henry & Associates (2025), citing Gartner Peer Community research: 57% skill gaps, 55% no AI governance framework.

Examiner readiness

What to have on the table when an examiner walks in, built on the AIEOG AI Lexicon vocabulary.

THE EXAMINER CONTEXT

The AIEOG AI Lexicon (US Treasury, FBIIC, FSSCC, February 2026) is a shared, non-binding AI vocabulary for the financial sector. Use its terms in your policy, your inventory, and your board reports so that your documents and your examiner's questions line up.

Key terms

Each entry gives a plain-language summary of the Lexicon definition, then what it means for your program. Read the Lexicon itself for the official wording.

Artificial intelligence (AI)

AIEOG AI LEXICON

A machine-based system that, for objectives people set, makes predictions, recommendations, or decisions that affect real or virtual environments.

AI governance

AIEOG AI LEXICON

The policies, rules, roles, and oversight that direct how an organization adopts, builds, deploys, and monitors AI, so AI risks are identified and managed across the lifecycle. **For you:** a board-approved policy and a named owner.

AI use case inventory

AIEOG AI LEXICON

A maintained listing of an organization's AI use cases, documenting where and how AI is used, for what purpose, and with what outputs. **For you:** add data inputs, risk tier, reviewer, and last-review date.

Hallucination

AIEOG AI LEXICON

AI output that is wrong or flawed but presented convincingly. **For you:** require human verification of facts and citations in any output used for a decision.

Human-in-the-loop (HITL)

AIEOG AI LEXICON

A risk control in which a human is built into the AI's decision process. **For you:** make HITL a mandatory, documented step for any credit- or compliance-related output.

Examiner readiness, continued

Explainability

AIEOG AI LEXICON

The property that lets a given audience understand why an AI system produced an output from its inputs. **For you:** under ECOA / Reg B, an adverse-action notice needs specific reasons. "The model said so" does not satisfy it.

Third-party AI risk

AIEOG AI LEXICON

Risk that arises when you rely on another entity to build, provide, host, or operate AI systems or key components such as models and data. **For you:** apply Interagency TPRM Guidance: due diligence, contract protections, ongoing monitoring, and concentration analysis.

Model risk

INSTITUTE SUMMARY • SEE SR 26-2

The potential for harm from decisions based on incorrect or misused model outputs. For generative AI, that extends to hallucinated outputs, prompt injection, and behavior changes after a vendor updates the underlying model.

Bias

AIEOG AI LEXICON

A systematic distortion, as opposed to random error, that makes an AI system's outputs less representative or accurate for its intended use. **For you:** in lending, test AI-assisted underwriting for disparate impact under ECOA / Reg B.

Generative AI

AIEOG AI LEXICON

AI that emulates the structure and characteristics of its input data to produce new synthetic content: text, images, code, or audio.

Review-ready document checklist

Keep a current version and a dated history of each item, so the record shows a program that has been operating, not one assembled for the exam notice.

- ☐ AI use case inventory — current, dated, owner assigned
- ☐ AI governance policy — board-approved, with an annual review cycle
- ☐ Vendor evaluation records for each AI tool (Chapter 4 scorecard or equivalent)
- ☐ Model-risk mapping against SR 26-2 principles (Chapter 3 framework or equivalent)
- ☐ Shadow AI discovery log — at least one completed cycle
- ☐ HITL documentation for every AI-assisted lending or compliance workflow
- ☐ Hallucination incident log (even if empty; the log shows awareness)
- ☐ Board presentation on AI governance within the prior 12 months

- ❑ Staff training records — AI acceptable-use training completion by role
- ❑ Adverse-action notice review — confirm AI-generated reasoning is not cited verbatim

BOARD REPORTING LANGUAGE

The Institute recommends a quarterly AI governance summary to the full board covering: (1) active AI tools by department and risk tier; (2) vendor evaluation changes; (3) shadow AI discovered and remediated; (4) staff training completion; (5) any incidents involving AI-generated output. Five slides, twenty minutes.

Sources: AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC (February 2026). SR 26-2, Revised Guidance on Model Risk Management, FRB / OCC / FDIC (April 17, 2026), superseding SR 11-7 (2011). GAO-25-107197, US Government Accountability Office (May 2025): no comprehensive AI-specific banking framework; oversight works through existing guidance. Interagency Guidance on Third-Party Relationships: Risk Management (June 2023). Cornerstone Advisors, AI Playbook for Banks and Credit Unions (2025).

This guide is for governance planning only and is not legal advice. Adapt before adoption, and confirm institution-specific requirements with your counsel and primary federal regulator. The AI Banking Institute · AIBankingInstitute.com · v1.1, October 2026.